Cybersecurity Incident Report

This is a Cybersecurity Incident Report for a fictional scenario given as an activity for the *Connect and Protect: Networks and Network Security Course* in Coursera

Scenario:
You work as a security analyst for a travel agency that advertises sales and promotions on the company's website. The employees of the company regularly access the company's sales webpage to search for vacation packages their customers might like.

One afternoon, you receive an automated alert from your monitoring system indicating a problem with the web server. You attempt to visit the company's website, but you receive a connection timeout error message in your browser.

You use a packet sniffer to capture data packets in transit to and from the web server. You notice a large number of TCP SYN requests coming from an unfamiliar IP address. The web server appears to be overwhelmed by the volume of incoming traffic and is losing its ability to respond to the abnormally large number of SYN requests. You suspect the server is under attack by a malicious actor.

You take the server offline temporarily so that the machine can recover and return to a normal operating status. You also configure the company's firewall to block the IP address that was sending the abnormal number of SYN requests. You know that your IP blocking solution won't last long, as an attacker can spoof other IP addresses to get around this block. You need to alert your manager about this problem quickly and discuss the next steps to stop this attacker and prevent this problem from happening again. You will need to be prepared to tell your boss about the type of attack you discovered and how it was affecting the web server and employees.

Link to Wireshark TCP/HTTP log: Wireshark TCP/HTTP log

Section 1: Identify the type of attack that may have caused this network interruption

One potential explanation for the website's connection timeout error message is a SYN flood attack, which is a type of denial of service (DoS) attack. The Wireshark log shows that from 3.144521 to 3.246989 seconds, visitor 198.51.100.23 completed a normal TCP three-way handshake with the web server (192.0.2.1) and received the sales page (HTTP 200 OK at 3.349457 seconds). Starting at 3.390692 seconds, the IP address 203.0.113.0 began sending SYN packets to the same server. After one completed connection, it kept sending SYN packets without finishing the handshake, until 51.823018 seconds. In this capture, 140 of the 174 packets (about 80%) came from this one address. Because all of the attack traffic comes from a single IP address, this is a DoS attack.

Section 2: Explain how the attack is causing the website to malfunction

When website visitors try to establish a connection with the web server, a three-way handshake occurs using the TCP protocol. It works as follows:

1. SYN: The visitor's computer sends a SYN packet to ask the server to open a connection.
2. SYN-ACK: The server replies with a SYN-ACK packet. The ACK part confirms it received the request, and the SYN part says it is ready to connect.
3. ACK: The visitor's computer sends an ACK packet to confirm. The connection is now open and they can exchange data.

So what happens when a malicious actor sends many SYN packets?

- In a SYN flood, the attacker sends a very large number of SYN packets and never sends the final ACK. For every SYN, the server replies with a SYN-ACK and keeps that half-open connection in memory while it waits for an ACK that never comes. As these pile up, the server runs out of room for new connections, so real visitors cannot connect. This is how a SYN flood exhausts server resources.

- The logs show 203.0.113.0 sending SYN packets again and again from 3.390692 to 51.823018 seconds, and only one of its connections was ever completed. Around 6.2 seconds, normal visitors began to fail: 198.51.100.16, 198.51.100.7, 198.51.100.22, and 198.51.100.9 received connection reset (RST, ACK) replies, and 198.51.100.5 received an HTTP 504 Gateway Time-out. After about 15 seconds, no new visitors appear in the capture. This explains the connection timeout error that employees saw, and why the server was taken offline to recover.

- While the server is overwhelmed, employees cannot open the sales page to find vacation packages for customers, and customers cannot see promotions or books. This can cause lost sales, a damaged reputation, and extra staff time spent responding to the incident.

- Blocking the IP address only helps for a short time, because an attacker can spoof other IP addresses. Longer-term options are to set limits on how many SYN packets one address can send, turn on SYN cookies on the server, use an intrusion prevention system (IPS) to detect and block floods automatically, and use a DDoS protection or content delivery service in front of the website.